

Conditional Access rollout plan — Contoso Pty Ltd

Baseline	Jon Hope — Defense in Depth CA baseline
Plan dates	Aug 30, 2026 → Oct 12, 2026
Pace	Standard
Generated	Aug 27, 2026

Prepared with IMAI by alex@example.com

Contents

1. Summary
2. Day 0
3. Wave 1 · Low-impact blocks
4. Wave 2 · MFA for everyone
5. Wave 3 · Admin hardening
6. Wave 4 · Guests and locations
7. Wave 5 · Devices
8. Wave 6 · Sessions

Summary

Contoso Pty Ltd: 2 of 18 steps already in place. 16 remain. With a standard pace, the plan finishes in 46 days · Oct 12, 2026 (6 weeks).

Danger areas

- **1 user is blocked today, before this plan changes anything** — Priya Nair

Timeline

WAVE	DATES	STEPS
Day 0	Aug 30, 2026	Answer 3 setup questions; Every user satisfies MFA on every app; Guests satisfy MFA
Wave 1 · Low-impact blocks	Sep 6, 2026 → Sep 10, 2026	Security-info registration requires a trusted context; Authentication transfer blocked; Device-code flow blocked; Legacy protocols blocked
Wave 2 · MFA for everyone	Sep 10, 2026 → Sep 24, 2026	Run the MFA verification campaign
Wave 3 · Admin hardening	Sep 24, 2026 → Sep 28, 2026	Admin sessions expire quickly and never persist; Admins use phishing-resistant auth; Admin portals need strong auth or are blocked for non-admins
Wave 4 · Guests and locations	Sep 28, 2026 → Oct 2, 2026	Sign-ins outside allowed countries blocked
Wave 5 · Devices	Oct 4, 2026 → Oct 8, 2026	Unknown platforms blocked; Registering or joining a device requires MFA
Wave 6 · Sessions	Oct 8, 2026 → Oct 12, 2026	Browser sessions never persist for anyone; Unmanaged devices cannot download; Unmanaged-device browser sessions are limited; Windows desktop sessions require token protection

Day 0

Aug 30, 2026

Answer 3 setup questions

Kind: Prerequisite · Status: Ready

WHY

A few answers about the tenant turn templates into exact, safe policy changes.

THE CHANGE

- Open the Setup step and answer: Emergency access, Exclusion group and Style choices.
- Each takes under a minute; every pick is validated.

DONE WHEN

- Every required Setup question answered.

IF IT GOES WRONG

Nothing destructive here — objects created can simply be deleted.

Every user satisfies MFA on every app

Kind: New policy · Status: Done

Already in force — no change for anyone.

WHY

Require MFA for all users on all apps - the single highest-value Conditional Access policy.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- 1 verified, 0 likely viable, 2 not challenged, 1 unverified, 1 without a method
- 25% of 4 active users ready

THE CHANGE

- Already delivered by existing policies — nothing to do.

DONE WHEN

- Stays enforced on every re-scan.

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Guests satisfy MFA

Kind: New policy · Status: Done

Already in force — no change for anyone.

WHY

External users get MFA too - their home tenant's hygiene is not your control.

WHO IS AFFECTED

1 person · 1 active · 1 guest

READINESS

- 0 verified, 0 likely viable, 1 not challenged, 0 unverified, 0 without a method
- 0% of 1 active user ready
- 1 active guest in the collected sign-in records

THE CHANGE

- Already delivered by existing policies — nothing to do.

DONE WHEN

- Stays enforced on every re-scan.

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Wave 1 · Low-impact blocks

Sep 6, 2026 → Sep 10, 2026

Security-info registration requires a trusted context

Kind: New policy · Status: Blocked

2 of 3 active users are not verified yet — they would be interrupted at their next sign-in.

WHY

Stop attackers registering their own MFA method on a compromised account.

WHO IS AFFECTED

4 people · 3 active · 1 admin

READINESS

- 1 verified, 0 likely viable, 1 not challenged, 1 unverified, 1 without a method
- 33% of 3 active users ready

Blocked by: readiness is 33% — the mfa threshold is 90%; verify users first (phase 2)

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Authentication transfer blocked

Kind: New policy · Status: Ready

Zero sign-ins would have been affected in the last 30 days — free security.

WHY

Authentication transfer moves a session to another device via QR code - block it unless used.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- Readiness is measured by usage — see who used this below.

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Device-code flow blocked

Kind: New policy · Status: Ready

Zero sign-ins would have been affected in the last 30 days — free security.

WHY

Device-code phishing is a favourite attacker technique; block the flow unless you need it for TVs/kiosks.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- Readiness is measured by usage — see who used this below.

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Legacy protocols blocked

Kind: Change · Status: Ready

1 user used this in the last 30 days and would be affected — contact them first.

WHY

Legacy protocols skip MFA entirely; blocking them closes the biggest password-spray door.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- Readiness is measured by usage — see who used this below.

THE CHANGE

- Extend the include scope: 1 expected user is never targeted.
- The covering policy is report-only — enforce it once the evidence is clean.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Revert the changed fields to their previous values; the previous body is in the policy history.

Wave 2 · MFA for everyone

Sep 10, 2026 → Sep 24, 2026

Run the MFA verification campaign

Kind: Verify · Status: Ready

3 active users need attention before MFA can be enforced safely.

WHY

Before MFA is enforced, every active user should have a working, verified method — enforcement should change nothing for them.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- 1 verified, 0 likely viable, 2 not challenged, 1 unverified, 1 without a method
- 25% of 4 active users ready

THE CHANGE

- Work the Readiness table top-down: 1 without a method (issue Temporary Access Passes), 1 unverified, 2 never challenged.
- Pilot suggestion: a handful of Verified users plus one admin; never break-glass or handle-with-care.

DONE WHEN

- Readiness reaches 90% of active users.

IF IT GOES WRONG

Nothing destructive here — objects created can simply be deleted.

Wave 3 · Admin hardening

Sep 24, 2026 → Sep 28, 2026

Admin sessions expire quickly and never persist

Kind: New policy · Status: Ready

All 1 active user is ready — enforcement changes nothing for them.

WHY

Short admin sessions that never persist limit what a stolen admin token is worth.

WHO IS AFFECTED

1 person · 1 active · 1 admin

READINESS

- 1 of 1 admin hold a phishing-resistant method

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Admins use phishing-resistant auth

Kind: New policy · Status: Ready

All 1 active user is ready — enforcement changes nothing for them.

WHY

Admins are the crown jewels: require passkeys/FIDO2 or certificate auth, not just push approvals.

WHO IS AFFECTED

1 person · 1 active · 1 admin

READINESS

- 1 of 1 admin hold a phishing-resistant method

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Admin portals need strong auth or are blocked for non-admins

Kind: New policy · Status: Blocked

3 of 4 active users are not verified yet — they would be interrupted at their next sign-in.

WHY

Gate the Microsoft admin portals behind strong auth.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- 1 verified, 0 likely viable, 2 not challenged, 1 unverified, 1 without a method
- 25% of 4 active users ready

Blocked by: readiness is 25% — the mfa threshold is 90%; verify users first (phase 2)

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Wave 4 · Guests and locations

Sep 28, 2026 → Oct 2, 2026

Sign-ins outside allowed countries blocked

Kind: New policy · Status: Blocked

4 active users in scope.

WHY

Block sign-ins from countries you never operate in.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- Compare the countries seen in the sign-in records with the allowed list.

Blocked by: Blocked until Setup question 6 — Style choices: a few policies come in two styles — pick one of each.

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IAMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Wave 5 · Devices

Oct 4, 2026 → Oct 8, 2026

Unknown platforms blocked

Kind: New policy · Status: Blocked

4 active users in scope.

WHY

If you only support Windows/iOS/Android/macOS, block everything else.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- 1 of 4 active members own a compliant device

Blocked by: device readiness is 25% — the threshold is 80%

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IAMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Registering or joining a device requires MFA

Kind: New policy · Status: Blocked

3 of 4 active users are not verified yet — they would be interrupted at their next sign-in.

WHY

Joining or registering a device should itself require MFA.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

READINESS

- 1 verified, 0 likely viable, 2 not challenged, 1 unverified, 1 without a method
- 25% of 4 active users ready

Blocked by: readiness is 25% — the mfa threshold is 90%; verify users first (phase 2)

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IAMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Wave 6 · Sessions

Oct 8, 2026 → Oct 12, 2026

Browser sessions never persist for anyone

Kind: New policy · Status: Ready

4 active users in scope.

WHY

No 'stay signed in' on shared or unmanaged browsers — sessions end when the browser closes.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IAMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Unmanaged devices cannot download

Kind: New policy · Status: Ready

4 active users in scope.

WHY

Let unmanaged devices read but not download from SharePoint and Exchange.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Unmanaged-device browser sessions are limited

Kind: New policy · Status: Ready

4 active users in scope.

WHY

On unmanaged devices, let people read but limit downloads and session lifetime.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.

Windows desktop sessions require token protection

Kind: New policy · Status: Ready

4 active users in scope.

WHY

Bind Windows sign-in tokens to the device so stolen tokens are useless elsewhere.

WHO IS AFFECTED

5 people · 4 active · 1 admin · 1 guest

THE CHANGE

- No baseline policy matches this goal directly — create a policy that meets the goal floor.

DONE WHEN

- Policy live in report-only for at least 7 days.
- At least 1 sign-in per active user in the population (or 500 total).
- Zero report-only failures or interruptions.
- The signed-in account has a strong method registered — IMAI checks this.
- Then enable the policy (Enforce).

IF IT GOES WRONG

Switch the policy back to report-only (or delete it); nothing else changes.